

DARI: Delegated Authorization and Receipts for Governed AI Inference

Patrick Rho
Patty Co., Ltd.

August 2026

Abstract

An AI coding agent can read a private repository, choose what leaves the machine, select a model, request tools, rewrite a file, and produce a commit. Yet after the commit exists, a basic accountability question remains difficult to answer: *who was authorized to cause it?* Today’s systems can usually recover pieces of the answer from API credentials, gateway decisions, tool logs, and Git history. They cannot reliably show that the same bounded authority governed the entire path from human intent to model invocation to executable side effect. This limitation motivates an authority-bearing exchange rather than independently correlated records.

We present DARI (Delegated Authorization and Receipts for Inference). Its neutral kernel consists of four objects: a *Credential* binds a peer to verification material; an *Authorization Grant* expresses signed, bounded authority; a *Governed Exchange* orders protected inference and effect transitions under that authority; and an *Evidence Receipt* commits to the resulting evidence. An Inference Peer is selected through a Model Artifact Manifest rather than a caller-supplied endpoint. A model may propose an action but cannot manufacture the authority to execute it.

The evaluated implementation establishes deterministic framing, canonical CBOR, and TLS/TCP and QUIC transport bindings. Transcript-bound peer authentication, canonical signed authorization scope, delegated attenuation, and deterministic final receipts are specification obligations whose complete protocol-source implementations and tests remain required. Browser and cross-domain federation bindings are extension profiles. On an Apple M4 Pro, a comparison bundle comprising a 1 KiB record round trip, evidence-chain update, object digest, and Ed25519 sign-and-verify totals 43.45 μ s. This equals 0.0097% of MLPerf Inference’s 450 ms interactive LLM time-to-first-token criterion, a difference of more than four orders of magnitude [10]. At 1 MiB, record encode/decode reaches 10.81 GB/s. These primitive measurements do not measure delegation, browser transport, federation, network policy, or end-to-end inference.

1 Introduction

Consider a plausible incident. A developer asks an agent to repair a failing authorization test. The agent selects six repository files as context, invokes a model advertised as “Model A,” receives a shell-tool proposal, runs a migration, edits two files, and creates a commit. Hours later, the migration is found to have exposed tenant data. The organization now asks:

- Which human and which installed agent initiated the work?
- Was that agent allowed to disclose those six files to that model?
- Which immutable policy version permitted the migration command?
- Did the model merely propose the command, or did an authorized runtime execute it?
- Which exact model artifact and Inference Peer produced the proposal?
- Which parts of the final commit survived from model output after human edits?

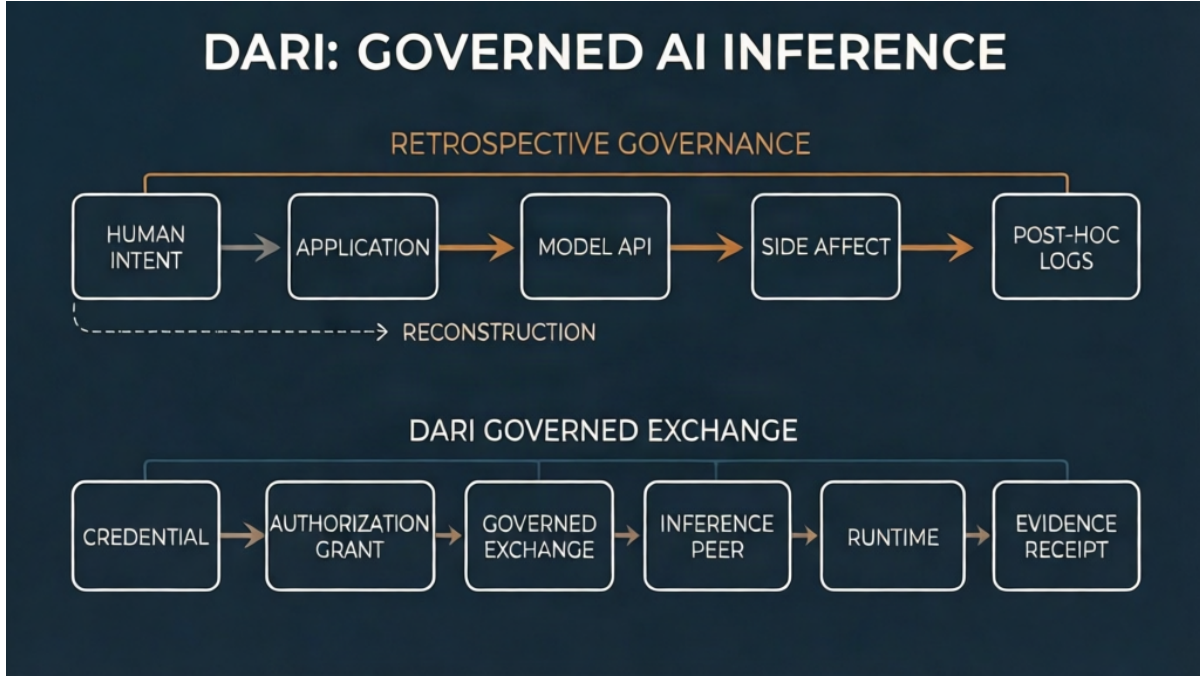


Figure 1: Comparison of retrospective governance and DARI’s governed exchange. DARI represents bounded authority, model identity, and causal evidence as conditions of the live path. The illustration is conceptual and contains no empirical data or implementation-coverage claim.

Each component may maintain a log, but those records describe different boundaries. API authentication identifies a caller; a gateway records routing or policy decisions; a sandbox records execution; and Git records the resulting artifact. Reconstructing a single causal and authorization account therefore requires correlating records produced under different identifiers, time sources, retention policies, and trust assumptions. Gaps or ambiguities may become visible only after the side effect has occurred.

This fragmentation reflects a *protocol-model gap*. Conventional AI interfaces transport prompts, tokens, tool calls, tasks, and artifacts without representing the bounded authority under which those objects may cause effects. Governance consequently remains external middleware rather than a condition on protocol state transitions. DARI incorporates identity, authority, policy, and causal evidence into the inference and action lifecycle.

DARI addresses this gap through an authority-bearing exchange. A protected exchange advances only when the relevant Credential, Authorization Grant, authorization decision, and Model Artifact Manifest agree; the existence of a TLS connection or model-generated tool call is insufficient. Figure 1 summarizes this protocol structure.

1.1 Contributions

The paper examines the thesis that *an agentic AI protocol should carry messages and actions together with the authority and causal evidence that make those actions legitimate*. It makes four contributions:

1. **Neutral protocol kernel.** We define Credential, Authorization Grant, Governed Exchange, and Evidence Receipt as the minimal authority and evidence objects for protected inference and effects.
2. **Delegated authority chain.** We define parent-bound, signed grants whose scopes attenuate monotonically, and separate a Model Artifact Manifest from the selected Inference Peer.
3. **Evidence-status boundary.** We distinguish the implemented framing and transport substrate from authentication, authorization, delegation, and receipt work that remains implementation-required.

4. **Open integration surface.** We separate the neutral kernel from application, browser, federation, and vendor-specific profiles so independent products can adopt compatible governed exchanges.

The contribution is compositional. Secure transport, capabilities, provenance DAGs, signed receipts, and tool protocols already exist; DARI integrates their authority semantics into one live state machine at the application–governance–inference/runtime boundary. The specification requires governance before an effect and evidence as a protocol output; the claim matrix states which parts of that construction are implemented.

2 The Governance Gap in Agentic AI Communication

The motivating incident exposes three mismatches that recur in agentic systems.

Authentication is not authorization history. A valid API credential can establish who opened a request without establishing which repository, purpose, tool class, model artifact, or side effect that identity was authorized to use throughout a long-running task. Agentic work outlives individual requests and crosses components whose authorization models are rarely identical.

Model output is not execution authority. Tool-calling formats make a proposed action machine-readable. They do not make it legitimate. If a model can cause execution merely by emitting the right syntax, untrusted repository text can attempt to acquire authority through prompt injection. The enforcement boundary must distinguish *proposal*, *approval*, and *execution* as different events with different principals.

Logs record events; they do not necessarily prove one causal path. Correlated identifiers help, but correlation is not the same as a protocol-enforced chain. A durable answer to “who authorized this commit?” must bind the action to the authority and policy that existed *before* execution, then preserve how its result changed through later human and automated work.

These mismatches suggest a missing layer between secure transport and application-specific governance: an exchange abstraction that carries identity, bounded authority, immutable policy, enforcement decisions, and evidence as coordinated protocol state.

3 Adjacent Systems and Novelty Boundary

Model APIs and gateways. HTTPS/JSON and streaming model APIs are effective request/response interfaces. Gateways can add authentication, quotas, policy, and logging. DARI differs primarily in the unit of state: authorization and evidence are bound to a governed exchange rather than reconstructed from independent middleware events.

MCP and A2A. The Model Context Protocol (MCP) standardizes interactions between AI applications and context/tool providers [11]. Agent2Agent (A2A) standardizes agent discovery, tasks, messages, and artifacts [1]. MCP can operate behind a governed tool broker, and A2A can operate at an agent-to-agent boundary. DARI targets the distinct boundary between an AI application, inline governance, controlled inference/runtime infrastructure, and evidence verification.

Runtime governance and agent security. MI9 examines integrated runtime governance for agentic systems [19]; AgentDojo provides an environment for prompt-injection attacks and defenses [6]; and argument-level provenance work highlights the mismatch between coarse authorization and tool arguments [7]. DARI is complementary: it defines protocol objects and state transitions through which identity, authorization, tool authority, and evidence can be enforced and exported.

Supply-chain provenance. in-toto records signed metadata about supply-chain steps [8, 18], while SLSA defines provenance expectations for build and source tracks [15]. SCITT defines transparency services for registering signed statements about digital artifacts and issuing receipts [4]. DARI addresses an earlier interactive phase, before a build artifact necessarily exists: it governs whether context, inference, and side effects may occur. A DARI receipt may later become an in-toto/SLSA attestation input or a SCITT statement, but artifact transparency does not replace live exchange authority.

Identity and cryptographic building blocks. SPIFFE provides workload-identity conventions [16]. DARI reuses TLS 1.3 [13], QUIC [9], deterministic CBOR [5], COSE [14], HPKE [2], TLS channel bindings [12], and COSE receipts [17]. These standards provide transport and object-security primitives; they do not define the application-level authority model proposed here. DARI’s monotonic delegation follows the capability-attenuation principle exemplified by Macaroons [3].

The novelty boundary follows from these roles: MCP describes tools, A2A describes inter-agent tasks, SPIFFE identifies workloads, gateways enforce policy, and in-toto attests supply-chain steps. DARI binds these adjacent concerns through a governed state machine at the transition from proposed computation to an authorized, durable effect.

4 Requirements and Threat Model

4.1 Design requirements

The incident questions become six protocol requirements: (R1) bind every protected action to an enrolled peer and human identity; (R2) constrain authority with short-lived, purpose-bound grants; (R3) bind every enforcement decision to an immutable policy revision; (R4) identify the served model artifact and endpoint more strongly than a caller-supplied name; (R5) separate model proposal from runtime authorization and execution; and (R6) emit causal evidence that survives beyond ordinary application logs.

The system must also operate with a temporarily unavailable administrative authority. Governance relays therefore consume signed or authenticated snapshots, revocation state, authorization grants, and model manifests. Availability under stale state is bounded by explicit expiration and deployment policy rather than implicit cache behavior.

4.2 Adversaries and non-goals

We consider network attackers, unregistered clients, stolen or replayed credentials, compromised applications, prompt-injected content, malicious tool output, model-name spoofing, cross-tenant mistakes, and evidence tampering. A Governance Relay or administrator may also be malicious or compromised. The protocol aims to make such authority and evidence boundaries explicit; it cannot make a trusted plaintext relay unable to inspect content, prove that a model behaved correctly, or prevent a fully compromised endpoint from acting outside the protocol. Hardware attestation and formal verification are optional assurance profiles, not assumptions required by the core protocol.

5 The Governed Exchange

The Governed Exchange is DARI’s unit of accountable AI work. It is larger than an API request and smaller than an entire application session. It begins when an application declares a protected purpose and ends with a receipt that commits to the resulting evidence. Within that boundary, inference, context disclosure, model selection, tool use, approval, and output are transitions of one authority-aware state machine.

A useful mental model is a transaction whose commit condition is governance rather than database consistency. TLS answers whether bytes arrived through a protected channel. The Governed Exchange additionally asks whether the sender, purpose, policy, model, and proposed effect agree. Failure at a required gate prevents the protected transition; it is not merely recorded for later review.

Table 1: Neutral DARI authority and identity objects. Objects visible to an application are intentionally separated from deployment identities.

Object	Authority	Purpose	Important distinction
Credential	enrollment authority	Binds key, peer profile, domain, and validity	Identifies a protocol peer, not merely a user
Authorization Grant	authorization authority	Grants bounded action/model/tool/context scope	Signed scope with explicit validity and audience
Authorization Decision	governance authority	Records the decision and obligations for a transition	Evaluation result; not authority by itself
Model Artifact Manifest	model authority	Identifies approved artifacts and serving configuration	Stronger than a human-readable model name
Inference Peer	serving authority	Presents a Credential and approved manifest	Deployment role; not caller-selected infrastructure
Governed Exchange	governance authority	Orders protected transitions under one grant chain	Unit of live authority and evidence
Evidence Receipt	receipt signer	Commits to exchange outcome and final evidence root	Verifiable output; deterministic implementation required

5.1 Architecture and peers

An administrative authority enrolls identities, issues authorization and model state, manages revocation, and indexes evidence. It is authoritative but is not placed synchronously on every token. A Governance Relay validates cached signed state, performs inline authorization decisions, routes approved inference, and appends evidence. An Inference Peer presents an approved Model Artifact Manifest and translates DARI’s semantic request into a local engine interface. A raw model endpoint is never routing authority for the application. An Effect Executor runs tools only after an independent authorization transition, and an Evidence Verifier checks the final receipt.

5.2 Protocol enforcement and retrospective logging

A log schema can describe an allow decision but cannot require that the decision precede disclosure, model allocation, or tool execution. DARI represents credential binding, grant presentation, authorization decision, dispatch, tool authorization, and closure as ordered protocol transitions. Peers must complete these transitions before protected work advances, distinguishing protocol enforcement from retrospective middleware records.

More precisely, let a be a protected action attempted during exchange x at time t . DARI permits the corresponding state transition only when

$$\text{advance}(x, a, t) = C_x \wedge G_x(a, t) \wedge D_x(a) \wedge R_x(a), \quad (1)$$

where C_x denotes a valid Credential binding, $G_x(a, t)$ is an unexpired Authorization Grant whose audience and scope cover a , and $D_x(a)$ is an allowing Authorization Decision under the bound policy state. $R_x(a)$ collects action-specific authority: inference requires an approved Model Artifact Manifest and Inference Peer, while a side effect requires independent tool authorization. Equation 1 is a protocol acceptance condition, not a formal security proof; failure of any conjunct blocks the protected transition. The corresponding verification and negative-test path is implementation-required rather than inferred from the implemented framing layer.

5.3 Transport and representation

QUIC is the preferred binding because independent streams reduce head-of-line coupling; TLS 1.3 over TCP is the fallback. Both use the same application semantics and ALPN identity. Records contain a fixed prelude, canonical

header, payload, logical lane identifier, and lane sequence. Deterministic CBOR provides reproducible object encoding. COSE signatures protect credentials, authorization grants, model manifests, and receipts where object-level verification is required.

Application authentication binds the Credential, nonces, negotiated profile, and channel context so that a credential proof captured on one connection cannot be replayed on another. DARI specifies this transcript-bound verification profile, but complete peer-authenticator implementation and negative tests remain required. The implemented evidence in this paper establishes the TLS/TCP and QUIC bindings, not the stronger authentication claim.

6 Authorization State Transitions

6.1 Credentials and Authorization Grants

User identity, application identity, and workload/session identity are separate because they answer different questions: who requested the work, which software installation carried it, and which bounded activity is now in progress. Enrollment gives a peer a Credential; it does not grant inference or tool authority. An Authorization Grant binds issuer, subject, audience, confirmation key, scope, validity, and an optional parent-grant hash. It grants only a subset of actions for a bounded interval: permitted models, context paths, tool classes, token budget, and approval requirements. Revocation or expiration prevents new protected actions even if the underlying transport remains healthy.

For delegation step i , DARI requires the signed child grant

$$G_i = \text{Sign}_{K_i}(\text{iss}, \text{sub}, \text{aud}, \text{cnf}, \text{scope}_i, t_{\text{nb}}, t_{\text{exp}}, H(G_{i-1})), \quad \text{scope}_i \subseteq \text{scope}_{i-1}. \quad (2)$$

The parent hash prevents detaching a child from its authority chain, while monotonic scope prevents delegation from amplifying authority. Canonical signed scope validation, parent-chain validation, and conformance tests for non-attenuating grants are implementation-required.

6.2 Authorization decisions and policy state

An Authorization Decision freezes the meaning of “allowed” for a transition by binding the grant, action, obligations, and a digest-addressed policy state rather than a pointer to whatever policy happens to be current when an auditor asks. If policy changes mid-session, active work follows an explicit continue, rebind, pause, or terminate rule; its historical meaning does not silently change. Before protected content reaches an Inference Peer or Effect Executor, the Governance Relay emits a structured decision such as allow, deny, transform, quarantine, or require approval.

6.3 Exchange lifecycle

A typical exchange progresses through OPEN, AUTHORIZE, ROUTE, STREAM, FINALIZE, and CLOSE, with an optional tool-proposal branch. These states are not descriptive labels; they constrain which messages are legal. The Governance Relay validates the Credential, Authorization Grant, Authorization Decision, Model Artifact Manifest, Inference Peer, and capacity state before dispatch. Token or data records are multiplexed over lanes with sequence numbers. Side-effecting actions carry an idempotency class so reconnect/resumption cannot silently duplicate a completed operation.

Applied to the motivating incident, the context disclosure is allowed or denied under the grant and bound policy state before six files leave the application. “Model A” resolves to a signed Model Artifact Manifest and authorized Inference Peer before inference. The shell string remains a proposal until a separately authorized Effect Executor transition runs it. The final receipt binds these decisions to the evidence root later associated with the commit.

Figure 2 makes the ordering explicit. The optional branch is whether a tool is proposed; authorization of a proposed tool is never optional.

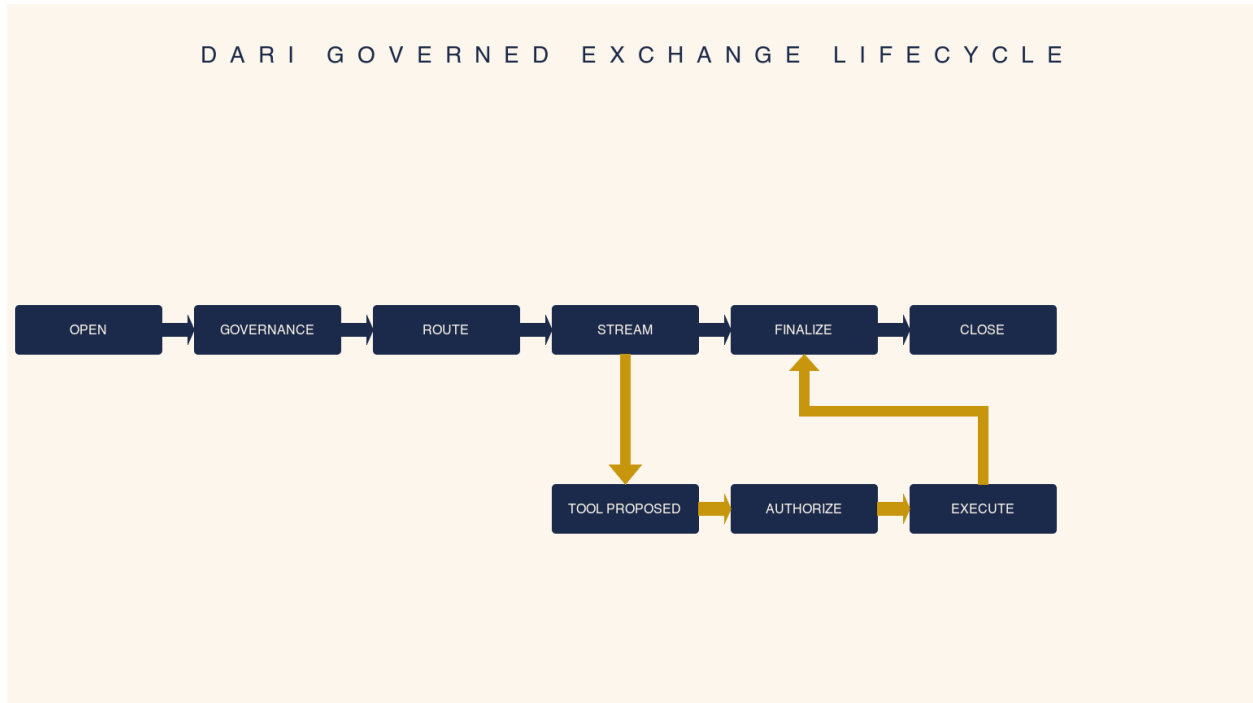


Figure 2: Conceptual protocol-design view of a Governed Exchange. Protected work advances through ordered authority gates; a model-generated tool proposal requires an independent authorization transition before execution. This figure specifies intended semantics, not measured implementation coverage.

6.4 Server-authoritative model resolution

DARI treats user-facing model names and security identities as distinct, and separates:

Service Model → Model Artifact Manifest → Inference Peer.

After authentication, the application receives an effective model catalog scoped by entitlement, organization policy, deployment profile, geography, and client capability. A Model Descriptor advertises semantic features—for example multimodal input, structured output, parallel tools, caching, reasoning controls, and resumability—without exposing an endpoint. An inference-open message references a stable Service Model and catalog revision. The Governance Relay rejects stale or unauthorized selections, resolves a signed Model Artifact Manifest, and selects an authorized Inference Peer. These are three deliberately different identities: the Service Model is visible to the user, the manifest identifies the approved artifact and serving configuration, and the peer identifies where that artifact may run now. A caller may express a preference; it cannot turn a string or base URL into trusted infrastructure.

Figure 3 shows how that separation prevents a user-visible name from becoming routing authority.



Figure 3: Protocol-design view of server-authoritative model resolution. Product, artifact, and deployment identities remain distinct until the Governance Relay resolves them to an enrolled Inference Peer; the serving engine is a local implementation detail, not an application-selectable endpoint.

6.5 Tool authority and prompt injection

DARI applies the following rule to prompt-injected output: *model output is a proposal, never authority*. Tool descriptors specify execution placement, risk class, argument schema, approval policy, idempotency, and provenance requirements. Incrementally streamed arguments are not executable until complete and authorized. Repository text, chat, files, and tool output retain trust labels but cannot enlarge grant scope. Injected text must therefore cross an independently controlled authority boundary. DARI records both the proposal and the decision that allowed, transformed, or denied execution.

7 Causal Provenance and Receipts

The audit objective is to establish how an artifact arose under a particular authority. The Evidence Graph represents causal edges among human intent, selected context, authorization decisions, model invocation, output, tool proposal, approval, execution result, edits, tests, review, and source-control artifacts. Nodes are content-addressed and typed; edges describe causation, derivation, disclosure, transformation, or binding. The absence of a required transition leaves a verifiable gap in the causal account. Events performed entirely outside the governed path remain outside the receipt’s observation boundary.

For compact exchange integrity, let $r_0 = H(\text{domain} \parallel \text{exchange-open})$ and

$$r_i = H(\text{domain} \parallel r_{i-1} \parallel H(e_i)), \quad (3)$$

where e_i is the canonical representation of evidence event i . A signed Evidence Receipt binds the final root to the exchange, identities, grant and policy-state digests, Model Artifact Manifest, outcome, and retention/export profile. The receipt is deliberately compact: an auditor given the complete ordered event sequence can recompute the root and verify consistency with the closed exchange. Proving an arbitrary selectively disclosed subset requires an additional commitment or inclusion-proof construction; the current chain primitive alone does not provide it. The deterministic final-receipt serializer and verifier are implementation-required.

The construction provides tamper evidence under explicit component trust assumptions. A compromised authorized component can emit false source data, and a coalition controlling every signer can manufacture a consistent account. Cross-component receipts and external transparency reduce unilateral trust but cannot establish the factual accuracy of source events. Cryptographic integrity and semantic truth are therefore treated as separate properties.

Selective-export profiles may replace sensitive nodes with commitments or redacted summaries, but their verifiable linkage is a design requirement rather than a property established by the current chain benchmark. Source-code attribution after refactoring or merging is probabilistic and should carry confidence and transformation history rather than a binary “AI-generated” label.

8 Evidence Status and Reference Profile

DARI is published as an open specification with a checked-in implementation-claim matrix. The benchmark snapshot is repository commit 0234034. That implementation establishes the record layer and transport bindings measured below; it does not by itself establish the stronger authentication, authorization, delegation, or receipt claims.

8.1 Authoritative implementation-claim matrix

8.2 Evaluated Patty compatibility profile

DARI evolved from Patty Co., Ltd.’s earlier internal protocol implementation. The evaluated compatibility profile preserves its deployed record and message semantics while the open specification generalizes authorization and receipt interfaces.

Table 2: Authoritative DARI implementation status. “Implementation-required” denotes required protocol-source and test work, not implemented behavior.

ID	Claim	Status	Evidence
C1	Deterministic framing and canonical CBOR	implemented	framing and serialization tests
C2	TLS/TCP and QUIC bindings	implemented	TLS/TCP and QUIC transport tests
C3	Transcript-bound peer authentication	implementation-required	transcript-authentication tests
C4	Canonical signed authorization scope	implementation-required	authorization tests
C5	Delegated authorization attenuation	implementation-required	delegation tests
C6	Deterministic final receipt	implementation-required	receipt tests
C7	Browser binding	extension-profile	dari.web/1 vectors
C8	Cross-domain federation	extension-profile	dari.federation/1 vectors

In this named reference profile, the Patty Code Harness is the application, the existing Relay supplies the Governance Relay role, and the Patty Inference Agent (PIA) supplies the Inference Peer role. The Patty Model Package (PMP) is the profile-specific predecessor of the neutral Model Artifact Manifest. The profile includes reusable vLLM and SGLang adapters and a custom `EngineAdapter` boundary. These names describe compatibility and integration evidence; they are not DARI kernel objects, and profile integration does not upgrade C3–C6 to implemented status.

9 Evaluation Questions and Baselines

The evaluation considers whether governance can be enforced while preserving interactive performance. It asks: (Q1) what connection and pre-inference latency does DARI add; (Q2) how does Governance Relay cost scale with streams; (Q3) what evidence and storage cost is associated with a verifiable causal path; (Q4) which adversarial cases are rejected by protocol state; and (Q5) how accurately provenance survives software evolution?

9.1 Baselines

We define five goal-aware baselines: B0, a minimal secure binary stream; B1, bearer-authenticated HTTPS/JSON streaming; B2, HTTPS/JSON plus comparable gateway policy and logging; B3, DARI with Credential and session binding but minimal governance; and B4, DARI with Authorization Grants, policy-state binding, content checks, Authorization Decisions, and evidence. The primary comparisons are B2 versus B4 (comparable governance, different lifecycle) and B3 versus B4 (the marginal cost of governance). MCP and A2A are treated as semantic neighbors rather than performance baselines.

End-to-end experiments must report connection p50/p95/p99, time to first Authorization Decision, TTFT, inter-token latency, sustained throughput, CPU time, allocation, memory per stream, and evidence bytes. The environment disclosure must include CPU, memory, NIC, RTT, topology, OS, runtime and transport-library versions, model/quantization, GPU, policy modules, and storage backend.

9.2 Security and provenance experiments

Negative tests include an unknown peer, expired or replayed grant, non-attenuating child scope, unknown policy-state digest, stale catalog, unapproved Model Artifact Manifest, invalid Inference Peer, profile-confused message, malformed state sequence, duplicate side effect after resume, prompt-injected authority escalation, and modified receipt. Provenance fidelity should be measured on generated functions followed by human edits, file renames, function moves, rebases, merges, and multi-agent changes. Precision/recall and confidence calibration are more appropriate than anecdotal examples.

Table 3: In-memory system-primitive medians over five runs. Record tests include encode and decode.

Operation	Time/op	B/op	allocs
Record, 1 KiB	290.2 ns	2,384	7
Record, 64 KiB	8.46 μ s	139,472	7
Record, 1 MiB	97.0 μ s	2,105,556	7
CBOR Hello round trip	599.4 ns	592	9
Evidence-chain update	73.05 ns	32	1
1 KiB object digest	403.1 ns	32	1
Ed25519 sign+verify	42.7 μ s	64	1

10 Measured System Primitives

10.1 Experimental setup

This paper isolates the evaluated implementation’s framing, cryptographic, and evidence primitives so that their cost remains visible rather than being absorbed into network or model variance. Measurements ran locally on an Apple M4 Pro with 14 logical CPUs and 48 GiB RAM under macOS 27.0 on arm64. Each benchmark was repeated five times; Table 3 reports the median. The resulting measurements provide a reproducible lower-layer baseline for the B0–B4 system comparisons. They do not measure Authorization Grant validation, attenuation, browser bindings, federation, or deterministic receipt finalization.

For operation o , the reported latency is

$$\tilde{t}_o = \text{median} \{t_o^{(1)}, t_o^{(2)}, \dots, t_o^{(5)}\}. \quad (4)$$

Only $\tilde{t}_o$ was retained in the artifact. The five individual observations were not retained, so the paper does not report dispersion, confidence intervals, or statistical significance.

Record encode/decode reaches 97.0 μ s for a 1 MiB payload, while its time per byte falls across the three measured sizes as fixed work is amortized. For record payload size s , we define size-normalized cost and effective payload throughput as

$$c(s) = \frac{\tilde{t}_{\text{record}}(s)}{s}, \quad q(s) = \frac{s}{\tilde{t}_{\text{record}}(s)}. \quad (5)$$

The measured $c(s)$ decreases from 0.283 ns/byte at 1 KiB to 0.0925 ns/byte at 1 MiB; equivalently, $q(s)$ rises from 3.53 to 10.81 GB/s (10.1 GiB/s). The 73.05 ns evidence-chain update is small enough to apply per evidence event, and a 42.7 μ s sign-and-verify operation is practical at exchange or receipt boundaries.

To give these isolated numbers an application-level point of reference, we construct a comparison bundle from four primitives used across the governed-exchange lifecycle: 1 KiB record round trip, evidence-chain update, object digest, and Ed25519 sign-and-verify. Their arithmetic sum is

$$L_{\text{DARI},1\text{KiB}} = 0.2902 + 0.07305 + 0.4031 + 42.688 = 43.45435 \mu\text{s}. \quad (6)$$

MLPerf Inference uses a 450 ms 99th-percentile TTFT criterion for interactive Llama 2 70B serving [10]. Relative to this reference,

$$\rho = \frac{L_{\text{DARI},1\text{KiB}}}{450 \text{ ms}} = 9.66 \times 10^{-5} = 0.0097\%. \quad (7)$$

The reference budget is more than 10,000 times larger than the combined primitive cost. Ed25519 sign-and-verify accounts for 98.2% of the bundle; framing, digest, and evidence-chain operations contribute the remaining 0.77 μ s. The measured primitive bundle is therefore four orders of magnitude below the interactive LLM response budget used for comparison.

To expose memory cost separately, let $B_{\text{op}}(s)$ be bytes allocated per record benchmark operation. Its allocation amplification is

$$A(s) = \frac{B_{\text{op}}(s)}{s}. \quad (8)$$

$A(s)$ falls from 2.33 at 1 KiB to 2.01 at 1 MiB. The benchmark allocates an encoded buffer and decoded record on every iteration; the large-payload allocation is therefore approximately twice the payload size and identifies a concrete optimization target.

Figure 4 makes the four-order-of-magnitude range visible; Table 3 remains the exact-value record.

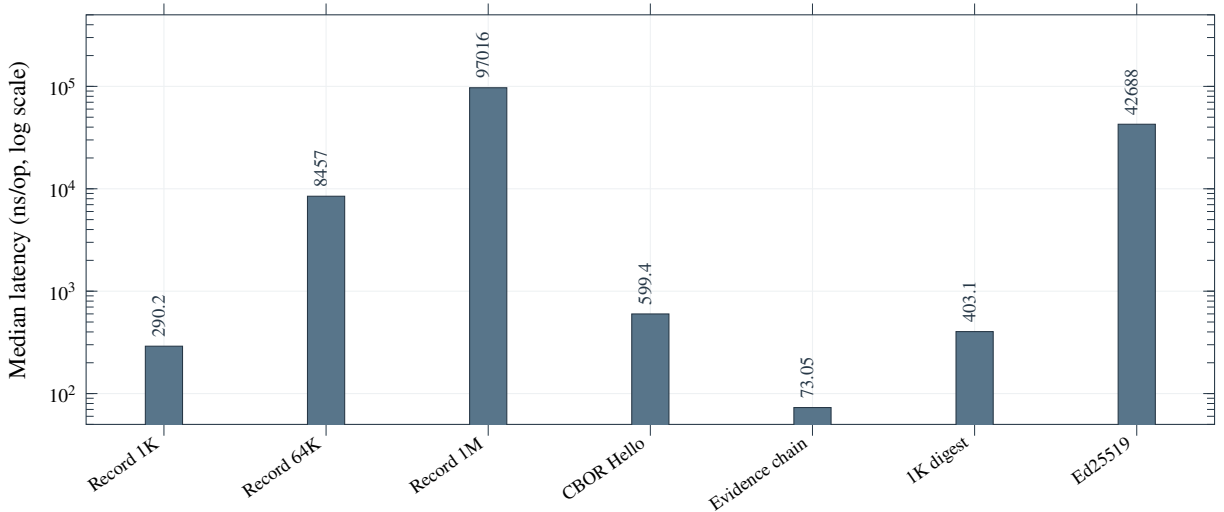


Figure 4: Empirical median latency of the seven measured in-memory primitives, read directly from the checked-in TSV and shown on a logarithmic axis. The isolated view makes the protocol’s CPU-side cost directly comparable with the interactive latency budget in Equation 7.

These primitives are the repeated building blocks for canonical evidence construction, indexing, retention, and signed receipts. Even before further allocation optimization, their combined 1 KiB cost consumes less than one ten-thousandth of the interactive TTFT reference budget, leaving substantial room for policy evaluation, transport, storage, and model serving.

The full repository suite passed at the evaluated commit. A separate coverage audit found that several conformance-test names exceed the properties exercised by their assertions. The package exposes tests named for invariants 1–5 and 7–12, with no named test for invariant 6; several passing tests exercise only a proxy for their stated property. For example, the legacy policy-state test checks connection readiness rather than unknown-state rejection, and the reconnect test contains no assertion. We therefore report repository test completion separately from invariant coverage. The detailed audit appears in Appendix A.

10.2 Interpretation

The comparison bundle occupies 0.0097% of the referenced interactive LLM latency target, while large-record processing exceeds 10 GiB/s. These measurements indicate that the evaluated primitive costs leave substantial latency

Table 4: Scope-aligned qualitative comparison of DARI and adjacent system families.

System family	Primary boundary	Live purpose-bound authority	Inline model/artifact identity	Interactive causal code provenance
Model API	application–model service	typically application-defined	usually caller-visible model identifier	external
AI gateway	application–provider mediation	gateway/policy dependent	provider-route dependent	logs/plugin-ins
MCP	AI application–tool/context provider	authorization is deployment-specific	not its objective	not its objective
A2A	agent–agent task/artifact exchange	protocol/task dependent	not its objective	not its objective
in-toto/SLSA	software supply-chain steps/artifacts	step/build policy	artifact identity	post-step/build provenance
DARI	application–Governance Relay–Inference Peer/runtime	Authorization Grant + bound policy state	Service Model + Model Artifact Manifest + Inference Peer	governed exchange graph/receipt

budget for TLS/QUIC establishment, policy modules, database/cache access, content classifiers, network placement, model scheduling, and evidence storage. B0–B4 experiments can quantify those system-level components, while the implementation-required negative-test suite must evaluate whether the Governance Relay converts DARI’s authority model into enforced denials.

11 Comparative Scope

Table 4 locates the contribution in composition and lifecycle semantics rather than lower-layer mechanisms. A conventional gateway could implement many DARI concepts; the empirical distinction is whether deployment-specific middleware and shared protocol state produce different interoperability, authority-gap, and failure-behavior outcomes. The proposed B2–B4 comparison is designed to measure this distinction.

12 Security Consequences of Externalizing Authority

DARI treats the model as an untrusted principal and constrains the authority available through its output channel. An unregistered generic client lacks a valid Credential and Authorization Grant. A stolen application key remains bounded by grant lifetime, repository/purpose scope, revocation, and optional device evidence. A fake model name cannot select an endpoint when the Governance Relay resolves only an authorized Service Model through a signed Model Artifact Manifest and authenticated Inference Peer. A prompt-injected tool call cannot grant itself authority because execution requires an independent authorization transition outside the model’s output channel. These are specified security consequences; C3–C6 identify the implementation work needed to claim their enforcement by the evaluated code.

Replay protection requires transcript-bound authentication and idempotency evidence. Transport fallback must preserve the same authorization objects and state machine. Evidence tampering changes the chain root, while an attacker able to compromise all receipt signers can still forge a consistent account. A malicious inspectable Relay can read plaintext and may omit or distort events; cross-component receipts, limited retention, independent export, and optional payload protection reduce but do not eliminate this trust.

These security properties require the protocol’s verification profile. The checked-in local-development profile uses self-signed certificates and simplified proof provisioning for installation convenience. A deployment profile may

require organization-issued Credentials, certificate verification, revocation, and transcript-bound proof validation. Such configuration does not substitute for the implementation-required peer-authenticator and authorization tests.

13 Incremental Gateway Migration

One protocol kernel supports public cloud, enterprise, and sovereign profiles by varying enabled modules, policy defaults, retention, mobility, and infrastructure placement rather than forking wire semantics. Sovereign deployments can use local PKI, catalogs, Inference Peers, and offline-signed update bundles. Browser binding and cross-domain federation remain extension profiles, and cross-vendor interoperability is not inferred from profile support.

Brownfield adoption can proceed through caller inventory, additive catalog/control schemas, parallel observation beside a legacy gateway, dual recording of comparable requests, canary application cohorts, and rollback gates. The evaluated Patty compatibility profile demonstrates preservation of the existing client and message boundary; it does not establish independent cross-vendor interoperability.

14 Discussion: Protocol Scope and Consequence Governance

DARI suggests that agent protocols should represent the consequences of messages in addition to their transport. Request authentication and application logs may be sufficient for systems that only return text. Systems that disclose private context, invoke tools, mutate repositories, and create durable artifacts also require authority over state transitions at the protocol boundary.

The protocol complements rather than absorbs adjacent standards. Its adoption criterion is the durability and privilege of an application's effects: a chat application can use identity, model authority, and evidence without enabling repository tools, while a coding agent can activate capabilities for durable state changes.

Application breadth. Inference, tools, context, files, chat, multimodal input, and directives share identity and session infrastructure while remaining capability-separated. This lets a conventional chat application adopt the same protocol core without inheriting file mutation or tool execution authority.

State and operations. Grants, policy-state digests, resumption, revocation, catalogs, and evidence add operational burden. Cache staleness and administrative-plane partitions require explicit fail-closed, bounded-stale, or degrade behavior. Binary framing also requires first-class diagnostics and capture tooling.

Privacy. Fine-grained provenance can become employee surveillance. Deployments need purpose limitation, minimization, role-separated access, retention bounds, selective export, and notice. Content-addressing does not anonymize sensitive content; unsalted hashes can enable guessing attacks.

Deployment and assurance profiles. The evidence package separates implemented substrate, implementation-required kernel behavior, and extension profiles. The measured profile provides primitive latency, throughput, and allocation results; the claim matrix identifies required authentication, authorization, delegation, and receipt work; and the research matrix identifies the experiments that deepen scale, provenance-fidelity, interoperability, and formal-analysis evidence. This separation prevents deployment intent from being mistaken for completed implementation.

Formal analysis. The state machine and invariants are candidates for formal modeling. This paper provides no formal security proof; provenance establishes recorded causality under component assumptions rather than semantic correctness or authorship truth.

15 Ethics and Surveillance Risk

Evidence about prompts, files, tool use, edits, and human decisions can improve incident response and accountability while also enabling disproportionate monitoring. The protocol therefore supports retention and export profiles, but technical configurability is insufficient. Deployments should establish lawful purpose, employee notice, access review, appeal, data-subject handling, and a separation between security investigations and performance management. Public deployments should default to operationally minimal traces; regulated deployments should justify deeper retention per policy domain.

Generated conceptual artwork is used for Figures 1 and 2; both communicate protocol architecture and contain no measurement or factual comparison. Figure 3 is a LaTeX-native protocol-design diagram. Figure 4 and the empirical tables are derived from the checked-in benchmark dataset; the retained medians are reproducible from the benchmark harness, while new statistical claims would require publication of raw per-run output.

16 Reproducibility

The arXiv source package contains the exact LaTeX source, bibliography, conceptual figures, benchmark dataset, implementation-claim matrix, and build instructions. The implementation repository contains the evaluated framing and transport substrate, benchmark harness, and the Patty compatibility profile described above. From the implementation repository root, the reported primitive measurements can be reproduced with:

```
go test ./... -run '^$' \
  -bench 'Benchmark(RecordRoundTrip|CanonicalCBOR|'\
'EvidenceChainNext|ObjectDigest|Ed25519SignVerify)$' \
  -benchmem -count=5
```

where the artifact README provides the complete regular expression. The PDF builds offline with `latexmk` and BibTeX. Raw per-run output, network/load generators, topology automation, negative-security fixtures, provenance datasets, and independent implementation results are required only for the corresponding stronger statistical, scale, attack-resistance, fidelity, or interoperability claims.

17 Conclusion

Accountability for an AI-generated commit requires more than identifying the model that produced its tokens. It requires evidence that the path from human intent to durable effect remained within bounded authority across context disclosure, model resolution, tool authorization, and artifact creation.

DARI represents this path as a Governed Exchange that binds a Credential, purpose, bounded Authorization Grant, policy state, Model Artifact Manifest, authorization decisions, and causal evidence. Model output remains a proposal, while independent protocol transitions authorize protected effects. An Evidence Receipt is the specified verifiable output of that path.

The evaluated implementation establishes deterministic framing, canonical CBOR, and TLS/TCP and QUIC bindings. Transcript-bound authentication, canonical signed scope, delegated attenuation, and deterministic final receipts remain implementation-required; browser and federation bindings are extension profiles. The measured primitive bundle occupies 0.0097% of the referenced interactive TTFT budget, and 1 MiB record processing reaches 10.81 GB/s. These values remain primitive measurements rather than evidence of the unimplemented or extension-profile claims.

Together, the specification, implemented substrate, compatibility lineage, and measured primitive costs define an evidence-bounded path toward governance as a shared protocol property connecting applications, authorization authorities, model infrastructure, tools, and causal evidence. The implementation-claim matrix makes the remaining work explicit.

References

- [1] A2A Project. Agent2agent protocol specification, 2026. <https://a2a-protocol.org/latest/specification/>.
- [2] R. Barnes, K. Bhargavan, and C. A. Wood. Hybrid public key encryption. Technical Report RFC 9180, IETF, Feb. 2022. <https://www.rfc-editor.org/info/rfc9180>.
- [3] A. Birgisson, J. G. Politz, Ú. Erlingsson, A. Taly, M. Vrable, and M. Lentczner. Macaroons: Cookies with contextual caveats for decentralized authorization in the cloud. In *Network and Distributed System Security Symposium*, 2014.
- [4] H. Birkholz, A. Delignat-Lavaud, C. Fournet, Y. Deshpande, and S. Lasker. An architecture for trustworthy and transparent digital supply chains. Technical Report RFC 9943, IETF, June 2026. <https://www.rfc-editor.org/info/rfc9943>.
- [5] C. Bormann and P. Hoffman. Concise binary object representation (CBOR). Technical Report RFC 8949, IETF, Dec. 2020. <https://www.rfc-editor.org/info/rfc8949>.
- [6] E. Debenedetti, J. Zhang, M. Balunović, L. Beurer-Kellner, M. Fischer, and F. Tramèr. AgentDojo: A dynamic environment to evaluate prompt injection attacks and defenses for llm agents. *arXiv preprint arXiv:2406.13352*, 2024. <https://arxiv.org/abs/2406.13352>.
- [7] L. Fan, Z. Li, Y. Tian, Y. Wang, R. Li, and X. Wang. The granularity mismatch in agent security: Argument-level provenance solves enforcement and isolates the llm reasoning bottleneck. *arXiv preprint arXiv:2605.11039*, 2026. <https://arxiv.org/abs/2605.11039>.
- [8] in-toto Project. in-toto specification v1.0, 2023. <https://in-toto.io/docs/specs/>.
- [9] J. Iyengar and M. Thomson. QUIC: A UDP-based multiplexed and secure transport. Technical Report RFC 9000, IETF, May 2021. <https://www.rfc-editor.org/info/rfc9000>.
- [10] MLCommons. MLPerf Inference v5.0 advances language model capabilities for GenAI, Apr. 2025. <https://mlcommons.org/2025/04/llm-inference-v5/>.
- [11] Model Context Protocol Project. Model context protocol specification, 2025-06-18 revision, 2025. <https://modelcontextprotocol.io/specification/2025-06-18>.
- [12] E. Rescorla. Channel bindings for TLS 1.3. Technical Report RFC 9266, IETF, July 2022. <https://www.rfc-editor.org/info/rfc9266>.
- [13] E. Rescorla. The transport layer security (tls) protocol version 1.3. Technical Report RFC 9846, IETF, July 2026. <https://www.rfc-editor.org/info/rfc9846>.
- [14] J. Schaad. CBOR object signing and encryption (COSE): Structures and process. Technical Report RFC 9052, IETF, Aug. 2022. <https://www.rfc-editor.org/info/rfc9052>.
- [15] SLSA Project. SLSA specification v1.2, 2026. <https://slsa.dev/spec/v1.2/>.
- [16] SPIFFE Project. Secure production identity framework for everyone standard, 2026. <https://spiffe.io/docs/latest/spiffe-specs/spiffe/>.
- [17] O. Steele, H. Birkholz, A. Delignat-Lavaud, and C. Fournet. CBOR object signing and encryption (COSE) receipts. Technical Report RFC 9942, IETF, June 2026. <https://www.rfc-editor.org/info/rfc9942>.
- [18] S. Torres-Arias, H. Afzali, T. K. Kuppusamy, R. Curtmola, and J. Cappos. in-toto: Providing farm-to-table guarantees for bits and bytes. In *28th USENIX Security Symposium*, pages 1393–1410, 2019.
- [19] C. L. Wang, T. Singhal, A. Kelkar, and J. Tuo. MI9: An integrated runtime governance framework for agentic ai. *arXiv preprint arXiv:2508.03858*, 2025. <https://arxiv.org/abs/2508.03858>.

A Assurance Matrix for Research Invariants

Table 5 audits the conformance-test coverage at the evaluated commit. “Weak” denotes an assertion that does not exercise the full invariant stated by its test name; “partial” denotes a meaningful primitive or state check without a complete end-to-end path.

Table 5: Coverage audit of the candidate research invariants.

ID	Candidate invariant	Coverage	Audit note
I1	No protected action before peer authentication	Partial	connection-state gating asserted; listener proof verification incomplete
I2	No protected action outside a valid Authorization Grant	Weak	test checks credential time validity, not action authorization
I3	No action under an unknown policy-state digest	Weak	test checks connection readiness, not policy-state lookup/rejection
I4	No invocation against an unapproved manifest/Inference Peer	Partial	signature mutation tested; full route binding not exercised
I5	Tool proposal grants no authority by itself	Weak	test checks only a valid peer credential
I6	Context disclosure requires explicit authority	Missing	no named conformance test
I7	Transport fallback preserves authorization semantics	Weak	ALPN constant checked; fallback exchange not exercised
I8	Reconnect does not duplicate completed side effects	Placeholder	named test has no assertion
I9	Protected exchange terminates with verifiable evidence	Partial	deterministic chain checked; termination/receipt path not exercised
I10	Provenance mutation changes digest	Implemented primitive	distinct content produces distinct domain-separated digest
I11	Peer profiles cannot emit privileged messages	Placeholder	message list is constructed but not passed through enforcement
I12	Administrative communication and enforcement are distinct	Structural	distinct message type codes asserted

A.1 Evidence Required for Stronger Claims

The following experiments extend the evidence associated with system-level performance, security, provenance, and interoperability claims:

1. **Transport and authentication:** exercise full certificate and COSE proof verification, revocation, transcript binding, resumption, and QUIC-to-TCP fallback with p50/p95/p99 connection measurements.
2. **End-to-end inference:** compare B0–B4 on identical payloads and model output, reporting Authorization Decision latency, TTFT, streaming throughput, CPU, allocation, and memory.
3. **Governance negatives:** reject expired or replayed grants, non-attenuating child scopes, unknown policy states, stale catalogs, unapproved manifests, invalid Inference Peers, profile-confused messages, and duplicate side effects through the actual Governance Relay path.
4. **Scale and failure:** measure concurrent sessions/streams, Governance Relay restart, administrative-authority loss, bounded-stale caches, capacity-authority loss, and evidence-backend degradation.
5. **Provenance fidelity:** publish a labeled dataset covering human edits, file/function moves, rebases, merges, and multi-agent changes with precision, recall, and confidence calibration.
6. **Independent evidence:** demonstrate an implementation not sharing the same implementation stack, publish golden vectors/fuzz results, and obtain an external security review for the production-security profile.